

MOVEit Transfer Zero-Day Attack

A Diamond Model Analysis and National Policy Response

Aditya Sudhir Nakadi

December 6, 2025

The Cl0p ransomware group exploited a zero-day SQL injection vulnerability in the Progress Software MOVEit Transfer platform in May 2023, which caused a breach in more than 2,700 organizations worldwide, leaking data from about 93.3 million individuals. Critical infrastructure across healthcare, finance, government, and education sectors was affected due to this supply chain attack.

This analysis utilizes the Diamond Model of Intrusion Analysis to structure the investigation of Adversary, Capability, Infrastructure, and Victim, and to interpret socio-political and technology meta-features (Caltagirone, Pendergast, and Betz 2013).

1 Application of the Diamond Model

1.1 Adversary

The U.S. government has attributed Cl0p (CISA 2023b), a cyber-criminal organization operating from Commonwealth of Independent States jurisdictions (not state-sponsored), as the actor in advisory AA23-158A, and the group publicly claimed the attack on June 6, 2023 (Rapid7 2023).

Instead of deploying file-encrypting ransomware, Cl0p moved to pure data exfiltration and extortion, threatening to leak stolen information publicly, instead of using file-encrypting ransomware. This "smash-and-grab" approach allowed the rapid compromise of thousands of victims during brief exposure windows before security patches were available (GTIG 2023).

Cl0p has consistently targeted the managed file transfer platform, first with Accellion File Transfer Appliance and more recently with Fortra's GoAnywhere MFT, demonstrating clear investment in vulnerabilities related to business-critical file transfer systems (Fortinet 2023).

1.2 Victim

The victim landscape was vast with cascading supply chain consequences. The immediate victims were organizations operating internet-accessible MOVEit installations, but the attack also impacted thousands of other organizations unrelated to the software.

This included severe impacts on healthcare organizations, such as Welltok with 14.76 million individuals affected (HIPAA Journal 2024a), and Delta Dental with 6.9 million records (HIPAA Journal 2024b). Government entities that reported compromises were the U.S. Department of Energy, the Louisiana Office of Motor Vehicles, and the Oregon DMV. The breach of the National Student Clearinghouse reached millions of student records, and major corporations such as Shell, British Airways, and Ernst & Young were on victim lists (Guardian 2023).

Geographically, 78.9% of the identified victims were based in the United States, followed by a significant share in Canada, at 13.5% (Emsisoft 2023). CISA estimated that more than 3,000 U.S. organizations and approximately 8,000 worldwide were affected (CISA 2023b).

The supply chain multiplier effect proved especially damaging: service providers such as Zellis and the Teachers Insurance and Annuity Association generated hundreds of secondary victims. Many organizations that never installed MOVEit suffered breaches simply because their vendors relied on the platform (Kapko and Himmel 2024).

1.3 Infrastructure

Cl0p’s infrastructure was clearly in preparation for some time, with researchers in cybersecurity identifying at least one IP address involved in the exploitation activity was already active since at least mid-January 2023, months before the start of such a campaign, thus indicating that this group had standing infrastructure ready to be used at a later time (GTIG 2023).

These attacks targeted the internet-exposed MOVEit applications on standard HTTP and HTTPS ports. The SQL injection vulnerability was exploited through a POST request to a legitimate MOVEit file, `guestaccess.aspx`, which granted unauthenticated access to underlying database functionality (Rapid7 2023). After initial compromise, Cl0p dropped a custom ASP.NET web shell, called LEMURLOOT, with filenames designed to appear similar to other legitimate files, such as `human2.aspx`, patterned to resemble the legitimate file `human.aspx`. The web shell needed authentication through specific HTTP headers and returned generic 404 messages when accessed without those headers to remain hidden on the victim systems (Emsisoft 2023).

For extortion, Cl0p continued to leverage the well-established `CL0P^_LEAKS` dark web portal, where it listed victims and published stolen data. This is a platform that has been active since at least 2020, demonstrating investment in the infrastructure for extortion over time (Emsisoft 2023).

1.4 Capability

The core capability of Cl0p was exploiting zero-day vulnerabilities in software used widely inside enterprise environments and the ability to weaponize those vulnerabilities. SQL Injection CVE-2023-34362 was critical with a CVSS of 9.8 (National Vulnerability Database 2023), enabling remote attackers to execute arbitrary SQL commands, thus accessing and modifying data from the database or even escalating privileges in it.

When the campaign started on May 27, 2023 (GTIG 2023), four days before Progress

Software disclosed the vulnerability and released patches on May 31, Cl0p already had exploit code. The custom LEMURLOOT web shell exhibits extensive knowledge by importing legitimate MOVEit libraries and using proper API functions against MOVEit.

with thousands of organizations compromised in the narrow four-day window. This, according to Rapid7 (2023), shows automated exploitation across the affected systems in a uniform way.

This shift away from classic encryption-based ransomware toward pure data exfiltration points to enhanced operational planning. By doing so, without the need for an encryption phase, Cl0p could maximize the number of victims who could be compromised before security updates cut off access.

1.5 The Social-Political Meta-Feature

This includes power asymmetry coupled with geographic factors, exploitation of trust-based relationships, and information asymmetry between the adversary and the victim. Geographical sanctuary grants Cl0p operational freedom.

Operating from CIS jurisdictions provides a de-facto safe harbor in which the reach of Western law enforcement is limited (GTIG 2023). This case is an example of how adversaries can project cyber operations globally from jurisdictions with minimal consequences, as arrests and financial bounties did not stop activity.

That attack leveraged fundamental trust relationships in the digital economy, whereby organizations deployed MOVEit for secure data exchange. The compromise of that very trust infrastructure allowed Cl0p to weaponize a system put in place for protection. Supply chain dependencies further amplify these impacts, since downstream organizations depend on the security of their service providers without visibility into the specific technologies in use.

Information asymmetry was further in favor of the adversary, as there was a four-day gap between exploitation and exposure. A lot of organizations could not yet identify which data

had flowed out, or if they had become indirect victims. The targets also faced a collective action problem: the payment of ransoms would finance further attacks, while resistance ran the risk of sensitive information leaking into the public sphere (Kapko and Himmel 2024).

1.6 The Technology Meta-Feature

Technological factors enabled both the effectiveness and scale of the attack, which turned out to indicate systemic vulnerabilities in how enterprise software is developed and secured.

The Managed File Transfer systems have become critical infrastructure. Organizations replaced legacy FTP systems with MFT solutions driven by HIPAA, PCI DSS, GDPR, and other regulatory requirements. This led to consolidation around a limited set of vendor products and, subsequently, created single points of failure. According to Rapid7, there were about 2,500 MOVEit instances internet-accessible when Cl0p initiated its campaign (Rapid7 2023).

This vulnerability underlines the consistent failures related to secure software development. SQL injection has been on the OWASP Top 10 for many years (OWASP 2021), and to have such a vulnerability in a software product marketed for secure file transfer shows systemic quality assurance gaps (CISA 2023a).

Zero-day economics created a race condition that defensive measures could not address. Thousands of organizations were compromised during the four-day window before patches were available, and even well-resourced organizations had no viable method to defend against an unknown vulnerability.

Supply chain amplification extended beyond MOVEit itself to interconnected business systems. Organizations acting as data aggregators centralized sensitive information from hundreds of downstream entities, so a single compromised instance generated cascading breaches across multiple sectors.

2 Policy Assessment

2.1 Justification of Focus on Level 9 (National)

The scale of impact required coordination beyond the capacity of individual organizations. With more than 3,000 U.S. organizations affected across critical infrastructure sectors, the incident exceeded what any single entity, or voluntary industry consortium, could address (CISA, 2023b).

Critical infrastructure protection is a priority for national security. Compromises of government entities such as the Department of Energy and multiple state Departments of Motor Vehicles, to significant healthcare and financial institutions, demonstrate that the cascading effects extend to fundamental state operations. Executive Order 14028 (Executive Office of the President 2021) has already set federal requirements for Software Bills of Materials (SBOM) and supply chain security, and therefore, precedents exist, along with mechanisms for more extensive policy intervention.

Market failures further justify national regulation. The persistence of SQL injection vulnerabilities, despite decades of awareness, indicates that market forces alone have not incentivized secure software development. This reflects classic information asymmetry, where customers cannot effectively assess vendors' security practices.

The organizational-level responses to those vulnerabilities have structural limits in what they could do: single organizations cannot review proprietary source code, smaller organizations lacked specialized resources, and the downstream victims had no relationship with MOVEit, yet suffered the breaches. The limitations also illustrate that organizational defenses alone are insufficient to compensate for systemic weaknesses in vendor development practices.

Transnational approaches face still other constraints. As noted earlier, Cl0p's location in CIS jurisdictions limits Western law enforcement's reach. International agreements take a very long time to negotiate; their enforcement is irregular. Available frameworks, such as the

Budapest Convention, do provide coordination, but are limited by persistent safe harbors and sluggish norm development.

In contrast, national authorities have regulatory authority, procurement leverage, enforcement capability, and the ability to coordinate public-private initiatives, and thus Level 9 policy intervention is the most viable and effective response.

2.2 Description of Policy Response

The United States should establish a strong national policy relating to vendor security practices, vulnerability disclosure, supply chain transparency, and incentives to invest in security.

- 1. Secure Software Development Mandate:** Building from the foundation established by Executive Order 14028 (Executive Office of the President 2021), national policy should include specific mandates for a federally enforceable secure software development lifecycle for commercial products that handle sensitive data. The mandates shall include security-by-design principles and threat modeling, third-party audits prior to major releases, protection against OWASP Top 10 vulnerabilities such as SQL injection, and analysis of software components. The mandates shall extend to cover software acquired by federal agencies and critical infrastructure operators to ensure the creation of market drivers to reward more robust application of security.
- 2. Software Liability Reform:** A negligence standard would impose liability on vendors for security breaches due to failure to follow established consensus development standards. Corresponding safe-harbor language would provide protection from liability for those vendors that could show their products conform to standards put in place by, but not limited to, the NIST Secure Software Development Framework; it would prohibit liability shields in the end-user agreements for software in use within critical infrastructure.
- 3. Improved Vulnerability Disclosure:** The federal government should mandate immediate disclosure of critical infrastructure vulnerabilities, such as those reportable to CISA,

specifically within 24 hours of their discovery, and require vendors to publish patches for critical vulnerabilities within five business days. Incentivizing coordinated disclosure over adversarial exploitation, creating a federal vulnerability rewards program may remove the four-day exposure window that allowed the breach of MOVEit.

- 4. Supply Chain Transparency:** The SBOM requirements should go beyond federal procurement and extend to critical infrastructure software in general. The service providers should provide information about their security-relevant technology stack in general. It would have helped reduce the information asymmetry that left victims unaware of their exposure to the exploit. The supply-chain-incident repository at a federal level would support cross-sector pattern recognition.
- 5. Critical Infrastructure Software Designation:** Critical infrastructure software would be a national designation, which includes MFT platforms and identity management systems. This designation would also put higher security standards on technologies in addition to mandated pre-deployment certification and routine third-party audits.

3 Conclusion

This attack against MOVEit shows how modern attacks use software supply chains and widely deployed vendor products. The following Diamond Model explains one way a capable adversary leveraged vendor vulnerabilities, automated infrastructure, and global dependencies to steal data on an unimaginable scale.

Organizational defenses are incomplete but necessary. The root vulnerability lies within the vendor ecosystem, and national-level reform intervention is needed. A response framed by standards of vendor security, increased disclosure, supply chain transparency, and accountability provides a workable means to reduce future risk emanating from supply chain attacks.

References

- Caltagirone, S., A. Pendergast, and C. Betz (2013). *The Diamond Model of Intrusion Analysis*.
- CISA (2023a). *Progress Software Releases Security Advisory for MOVEit Transfer*. URL: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23%2D158a>.
- (2023b). *StopRansomware: CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability*. URL: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23%2D158a>.
- Emsisoft (2023). *Unpacking the MOVEit Breach: Statistics and Analysis*. URL: <https://www.emsisoft.com/en/blog/44123/unpacking-the-moveit-breach-statistics-and-analysis/>.
- Executive Office of the President (2021). *Executive Order 14028: Improving the Nation’s Cybersecurity*.
- Fortinet (2023). *Ransomware Roundup: Cl0p*. URL: <https://www.fortinet.com/blog/threat-research/ransomware-roundup-cl0p>.
- Google Cloud Threat Intelligence Group (2023). *Zero-day Vulnerability in MOVEit Transfer Exploited for Data Theft*. URL: <https://cloud.google.com/blog/topics/threat-intelligence/zero-day-moveit-data-theft>.
- Guardian, The (2023). *M MOVEit Transfer hack: Department of Energy among victims of mass data theft*. URL: <https://www.theguardian.com/technology/2023/jun/16/moveit-transfer-hack-department-of-energy>.
- HIPAA Journal (2024a). *Delta Dental of California Data Breach: 7 Million Individuals Affected*. URL: <https://www.hipaajournal.com/delta-dental-california-data-breach/>.
- (2024b). *Welltok Data Breach*. URL: <https://www.hipaajournal.com/welltok-data-breach/>.

Kapko, Matt and Julia Himmel (2024). *Progress Software’s MOVEit meltdown: uncovering the fallout*. URL: <https://www.cybersecuritydive.com/news/progress-software-moveit-meltdown/703659/>.

National Vulnerability Database (2023). *CVE-2023-34362 Detail*. URL: <https://nvd.nist.gov/vuln/detail/CVE-2023-34362>.

OWASP (2021). *OWASP Top 10 — 2021*. URL: <https://owasp.org/Top10/>.

Rapid7 (2023). *ETR: CVE-2023-34362 MOVEit Vulnerability Timeline of Events*. URL: <https://www.rapid7.com/blog/post/2023/06/14/etr%2Dcve%2D2023%2D34362%2Dmoveit%2Dvulnerability%2Dtimeline%2Dof%2Devents/>.